

Security+ 2.4 · Spyware & Bloatware

Mestre CyberSec · Lesson 2.4 — Spyware & Bloatware (4:21) · [Assistir Vídeo no YouTube ↗](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Spyware: coleta informação sem teu knowledge (tracking, keylogger de software). Bloatware: software pré-instalado inútil (superfície extra). Adware: propaganda. PUP: Potentially Unwanted Program. Defesa: AV com anti-spyware, política de instalação, avaliar permissão de apps.

💡 Key Exam Highlights & Critical Concepts

- Spyware: coleta SENHA SEM autorização; bloatware: pré-instalado inútil
- PUP (Potentially Unwanted) 'não é malware, mas você NÃO pediu'

🎯 Exam Tips & Typical CompTIA Scenarios

- 'tracks user behaviour without consent' = spyware

Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Spyware & Bloatware)

Why is this advanced coverage required for SY0-701? Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Spyware

Malware that covertly gathers information about a user and their activity — browsing habits, credentials, and personal data — without their knowledge or consent.

⚠ **Exam Trap:** Gatilho literal da prova: 'tracks user behavior without consent' = spyware. Coleta silenciosa e secreta = spyware; não confunda com adware (foco em anúncios) nem com PUP (indesejado, mas não secreto).

• Keylogger

A spyware variant, implemented in software or as a hardware device on the keyboard cable, that records every keystroke to capture passwords and other sensitive input.

⚠ **Exam Trap:** Gatilho: 'registra teclas / senha digitada' = keylogger. Pegadinha clássica: keylogger de HARDWARE existe — a prova pode descrever dispositivo físico inserido entre teclado e computador, não só software.

• Bloatware

Unnecessary pre-installed software shipped by manufacturers or carriers; it is not inherently malicious but consumes resources and expands the device's attack surface.

⚠ **Exam Trap:** Gatilho: 'pré-instalado e inútil' = bloatware. Pegadinha: bloatware NÃO é malware por definição — o risco do exame é a superfície de ataque EXTRA que cada aplicativo inútil adiciona ao sistema.

• Potentially Unwanted Program (PUP)

Software the user did not explicitly request, commonly bundled with other installers; it is not classified as malware but should be evaluated and removed.

⚠ **Exam Trap:** Citação de prova: 'is not malware, but you did NOT ask for it' = PUP. Distinção-chave: PUP = indesejado (você sabe que está lá, não quer); spyware = oculto (você nem sabe que está coletando).

• Adware

Software that delivers unsolicited advertising and pop-ups, often classified alongside PUPs; it may also profile browsing activity to target advertisements.

⚠ **Exam Trap:** Foco em propaganda/pop-ups = adware. Lógica da prova: adware vende atenção (anúncios); spyware rouba informação (coleta sem consentimento). Se a questão diz 'without consent', pense spyware.

• Tracking Cookie

A cookie that follows a user across multiple websites to build a behavioral profile of browsing activity, a common spyware-style tracking technique.

⚠ **Exam Trap:** 'Monitors browsing/surfing habits' pode ser tracking. Distinção fina: cookie rastreia navegação web; keylogger rastreia teclas; spyware é o guarda-chuva da coleta sem consentimento.

• Anti-Malware (Anti-Spyware)

Endpoint protection software (modern antivirus with anti-spyware features) that detects, quarantines, and removes spyware, adware, and PUPs.

⚠ **Exam Trap:** Mitigação padrão na prova: manter anti-malware/anti-spyware ATUALIZADO. O SY0-701 usa a nomenclatura moderna 'anti-malware' em vez de somente 'antivírus' — reconheça os dois como equivalentes.

• Application Installation Policy (App Permissions Review)

Administrative rules that limit which applications may be installed and require evaluating app permissions before approval, such as rejecting a flashlight app that requests access to contacts.

⚠ **Exam Trap:** Mitigação de bloatware/PUP = política de instalação + revisão de permissões. Sinal de alerta no exame: permissão incongruente com a função do app (lanterna pedindo contatos ou localização) = não instalar.

✓ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A payroll administrator at a finance company reports that her online banking credentials were used to transfer funds without her knowledge. Forensic analysis of her workstation reveals a hidden background process that captured everything she typed, including passwords, and transmitted the data to an external server. Which type of malware is responsible for this incident?

- A) Ransomware that encrypted the victim's files and demanded payment
- B) A software keylogger, which is a category of spyware
- C) A polymorphic worm that self-replicated across the network
- D) A boot sector virus that corrupted the master boot record

QUESTION 2 · EXAM SCENARIO

A company purchased 200 new laptops directly from a manufacturer. The security team discovers the devices ship with dozens of pre-installed applications the company will never use: trial antivirus suites, shopping toolbars, and vendor promotional utilities. Which action best reduces the resulting security risk before deployment?

- A) Reimage each device with a standardized corporate image containing only approved software
- B) Enable full-disk encryption on every laptop before distributing it to staff
- C) Configure device screen locks and enforce a strong password policy on each unit
- D) Update all of the pre-installed applications to their latest versions before deployment

QUESTION 3 · EXAM SCENARIO

During a software inventory review, technicians discover that a popular free PDF converter downloaded by several employees also silently installed a browser toolbar, a scheduler utility, and a second antivirus product. None of these extras were clearly disclosed during installation, and no one in the company uses them. Under the classification scheme, how should these bundled extras be categorized?

- A) Boot sector viruses that infected the partition table
- B) Zero-day exploits targeting the PDF converter
- C) Potentially Unwanted Programs (PUPs)
- D) Distributed denial-of-service attack tools

QUESTION 4 · EXAM SCENARIO

Several marketing employees complain that after visiting online shopping sites, they see advertisements for those exact products on completely unrelated websites, and the ads follow them across different browsers and devices. Web proxy logs show no malware downloads. Which mechanism is most likely responsible for the personalized advertising?

- A) A hardware keylogger attached to the employees' keyboards
- B) DNS poisoning on the corporate DNS resolver
- C) A session hijacking attack against the web proxy
- D) Tracking cookies that share a common identifier across websites

QUESTION 5 · EXAM SCENARIO

The help desk has received multiple tickets from the sales department. Users' browsers constantly open pop-up advertisements, home pages change on their own, and search results are injected with sponsored links. However, files and applications open normally and no data appears to have been stolen. Which category of malware best describes this infestation?

- A) Adware
- B) Crypto-malware
- C) A rootkit
- D) A logic bomb

QUESTION 6 · EXAM SCENARIO

Under the company's new application installation policy, an employee requests approval to install a free flashlight utility on her company-issued smartphone. The store listing shows the app requests permission to access contacts, SMS messages, precise location, and the microphone — far beyond what a flashlight needs. What is the most appropriate response under the policy?

- A) Approve the request, because vendor app stores automatically vet every published application
- B) Approve the request, but instruct the employee to dismiss all permission prompts after installation
- C) Reject the request, because the permissions requested are excessive for the app's stated purpose
- D) Approve the request, and disable the phone's mobile data so the app cannot exfiltrate anything

QUESTION 7 · EXAM SCENARIO

An audit finds that endpoints at a logistics firm have no protection against software that silently monitors user activity. Management wants a single control that can both detect known monitoring software already present on hosts and automatically remove it. Which control best meets this requirement?

- A) Enabling full-disk encryption with a strong recovery key on every endpoint
- B) Deploying an anti-malware suite with current anti-spyware signatures on every endpoint
- C) Implementing remote wipe and geofencing through the MDM platform
- D) Requiring complex passwords with 90-day expiration for all endpoint accounts

QUESTION 8 · EXAM SCENARIO

A security analyst at an investment firm is reviewing an endpoint suspected of running unauthorized monitoring software without the user's knowledge. Which of the following observations most strongly supports this suspicion?

- A) The workstation's system drive is fully encrypted and the machine boots normally
- B) The user reports frequent pop-up advertisements while browsing the web
- C) The browser cache contains several third-party tracking cookies
- D) A windowless background process captures keyboard input and periodically uploads small encrypted payloads to an unknown external IP address

QUESTION 9 · EXAM SCENARIO

A company buys employee smartphones directly from a carrier. The devices include many pre-installed carrier and promotional apps that cannot be uninstalled; some request network access and run in the background even though employees never open them. What is the primary security concern with these applications?

- A)** They expand the attack surface, since unused software may contain exploitable flaws or hidden data collection
- B)** They drain the battery and consume storage, shortening the devices' usable life
- C)** They block the MDM server from enrolling the devices into management
- D)** They make the devices incompatible with the corporate email platform

QUESTION 10 · EXAM SCENARIO

Over the past quarter, technicians have repeatedly removed browser toolbars, trial software, and unwanted utilities that employees installed alongside legitimate free downloads. Leadership wants a preventive control that stops these additions while still allowing approved business software. Which control best achieves this goal?

- A)** Publishing a monthly security newsletter that describes emerging spyware techniques
- B)** Enforcing an application installation policy that allows only approved software and requires a review of requested permissions
- C)** Configuring antivirus to run full-disk scans daily instead of weekly
- D)** Scheduling weekly disk cleanup and defragmentation tasks on every endpoint

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — A software keylogger, which is a category of spyware

The hidden process silently captured everything typed — including credentials — and transmitted the data to an attacker-controlled server. That is the defining behavior of a software keylogger, a type of spyware that collects information without the user's knowledge. Ransomware encrypts files for extortion, worms self-replicate to spread, and boot sector viruses corrupt the boot record; none of them steal credentials by capturing typed input.

Question 2: Option A — Reimage each device with a standardized corporate image containing only approved software

Bloatware is the unwanted, pre-installed software vendors ship on new devices. Every unused application is extra code that may contain unpatched vulnerabilities or hidden data collection, so removing it shrinks the attack surface. Reimaging with a clean corporate standard build is the accepted practice. Full-disk encryption protects data at rest, screen locks protect access, and merely updating the pre-installed apps keeps the unnecessary software — and its risk — in place.

Question 3: Option C — Potentially Unwanted Programs (PUPs)

Software that arrives bundled with a legitimate download, installs without clear disclosure, and serves no business purpose is classified as a Potentially Unwanted Program (PUP). PUPs expand the attack surface, consume resources, and frequently carry adware or telemetry. They are not viruses or exploits in this scenario, and they have nothing to do with DoS attacks; classifying them as PUPs drives the proper remediation of removal and policy filtering.

Question 4: Option D — Tracking cookies that share a common identifier across websites

The ads follow users across unrelated websites and even across browsers and devices, with no malicious downloads detected. This is the fingerprint of tracking cookies: small files that share a persistent identifier with advertising networks, which use them to build behavioral profiles and serve targeted ads. A keylogger would capture credentials rather than personalize ads, DNS poisoning misdirects name resolution, and session hijacking takes over live sessions — none of these produce cross-site personalized advertising.

Question 5: Option A — Adware

Pop-ups, hijacked home pages, and injected sponsored links are the classic symptoms of adware, which monetizes infected systems by forcing advertising in front of users. Files open normally and nothing was stolen, which rules out crypto-malware (which encrypts data for ransom); there is no evidence of hidden privileged code typical of a rootkit, and a logic bomb performs malicious actions when triggered, not continuous unwanted advertising.

Question 6: Option C — Reject the request, because the permissions requested are excessive for the app's stated purpose

Application permission review compares each requested permission against the app's legitimate function. A flashlight has no plausible need for contacts, SMS, precise location, or microphone access; such overreach is a textbook indicator that the app may spy on the device, so the installation should be rejected. Store vetting is not a guarantee of safety, dismissing prompts after install is unreliable, and cutting mobile data does not address the excessive device permissions the app already demands.

Question 7: Option B — Deploying an anti-malware suite with current anti-spyware signatures on every endpoint

Modern anti-malware packages bundle anti-spyware capability: with current signatures and heuristics, they detect known keyloggers, tracking components, and monitoring software already present on a host, and can quarantine or remove it automatically. Full-disk encryption protects data at rest, MDM remote wipe protects lost or stolen devices, and password policy hardens authentication — none of these controls can detect or remove monitoring software that is already running.

Question 8: Option D — A windowless background process captures keyboard input and periodically uploads small encrypted payloads to an unknown external IP address

The hallmark of keylogging spyware is a covert process that records keyboard input and secretly exfiltrates the captured data; periodic small uploads to an unknown IP address are the classic exfiltration pattern. Pop-up ads point to adware, third-party tracking cookies point to web tracking rather than local keystroke capture, and full-disk encryption is a protective control — none of these indicate covert monitoring.

Question 9: Option A — They expand the attack surface, since unused software may contain exploitable flaws or hidden data collection

Bloatware's principal security risk is the enlarged attack surface: every pre-installed app is additional, often unremovable code that runs with device privileges, may contain unpatched vulnerabilities, and may collect or transmit data even if the user never opens it. Battery and storage drain are operational annoyances rather than security risks, and pre-installed apps do not normally prevent MDM enrollment or break corporate email.

Question 10: Option B — Enforcing an application installation policy that allows only approved software and requires a review of requested permissions

An application installation policy is the preventive control that stops toolbars, trialware, and bundled utilities at the approval gate: only whitelisted, approved software may be installed, and requested permissions are reviewed before installation. Newsletters raise awareness but enforce nothing; more frequent antivirus scans may catch known malware but often miss PUPs and never prevent installation; disk cleanup and defragmentation are performance maintenance with no bearing on what gets installed.